TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

CISA adds Apple CVE-2024-27834 to KEV as APT29-linked watering holes hit iPhones and Androids

From **Cybersecurity Briefing** · 2026-11-04 to 2026-11-05 (last 24 hours; Indiana sections swept back to the 2026-10-31 cutoff) · Briefing generated 2026-11-05

REPORT ID	VERSION	HANDLING
CTI-20261105-03	1.0 · 2026-11-05 08:11 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-04	2026-11-05
CVES	**ANALYST**	
CVE-2024-27834 (CVSS 5.5), CVE-2025-43529 (CVSS 8.8), CVE-2026-20700 (CVSS 7.8), CVE-2025-14174 (CVSS 8.8), CVE-2025-43510 (CVSS 7.8), CVE-2025-43520 (CVSS 5.5), CVE-2026-3910 (CVSS 8.8), CVE-2025-27038 (CVSS 7.5)	Nick Sturgeon	

NATION-STATE | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CISA added CVE-2024-27834 to its Known Exploited Vulnerabilities catalog on 4 November 2026, with a federal due date of 18 November [S8] [S10]. The flaw is a pointer authentication (PAC) bypass in Apple's WebKit, fixed in May 2024 and first shown at Pwn2Own that March [S4] [S11] [S12]. Its CVSS score of 5.5 understates its practical role: an attacker needs arbitrary memory read and write first, which is why it serves as one link in a browser exploit chain and not as a stand-alone attack [S2] [S9]. The listing came the same day Sekoia published 'Poisoned Source', a report assessing with moderate-to-high confidence that APT29 (Midnight Blizzard, tied to Russia's SVR) ran watering holes against iPhone and Android users [S2] [S3]. CISA has not publicly attributed the exploitation, according to Help Net Security, although CISA's own data added to the CVE record cites the Sekoia report as a reference [S6] [S9].

Three delivery routes led to the same fingerprinting script: JavaScript injected into legitimate sites, reverse-proxy lookalike domains, and a one-week compromise of the Ukrainian Plerdy analytics tracker

from 27 August to 3 September 2026 [S2] [S3]. Described victims include a Ukrainian gas producer, a U.S. chemical industry trade association, a Bulgarian military-related site and a far-right Czech movement's site; the lookalikes imitated America250 and Raffles London at The OWO [S1] [S2] [S5]. The server then picks a chain by device. Class A targets iOS 16.7 and steals cookies using CVE-2025-43529 and CVE-2024-27834. Class B targets iOS 18.5, uses the DarkSword kit with five CVEs, and harvests messages, app databases, Keychain items, Wi-Fi passwords, location caches, photos and iCloud Drive files. Class C targets Chrome 139-145 on Android (excluding 143) using CVE-2026-3910 and CVE-2025-27038, and runs a payload called AndroSnitch to take Chrome cookies, saved logins, history and Wi-Fi configuration [S2] [S3].

Every flaw was patched before the campaign began, and Sekoia states that a user on an up-to-date operating system is safe from these chains, so the exposure is devices that are behind on updates [S2]. All eight CVEs are now in KEV; only CVE-2024-27834 has an open federal deadline [S8] [S10] [S27] [S28] [S29] [S30] [S31] [S32] [S33]. Nothing persists on the device, so a reboot stops the activity, but cookies and passwords already taken remain useful to the attacker [S1] [S6]. Two caveats apply. Android's Qualcomm fix depends on the device maker shipping the 2025-08-05 patch level [S23] [S24]. For iPhones capped at iOS 16, Apple's notes show the PAC fix in 16.7.8, but the iOS 16.7.16 notes do not list CVE-2025-43529; Apple told BleepingComputer in March that the latest iOS 15 through 26 releases were protected from DarkSword and Coruna, so these devices should be on 16.7.16 at minimum and are a replacement priority [S11] [S18] [S21].

Not yet known: how many devices were compromised, how the attacker got into the sites and Plerdy, whether stolen cookies were used against corporate accounts, and whether any U.S. visitor was actually exploited. Sekoia itself cannot say if the goal was selected visitors or wide collection [S3]. Defenders should move mobile fleets to current releases (iOS 27.2, 26.7.2 or 18.7.11, and current Chrome) [S13] [S34], confirm Macs and other Apple devices are also current since the KEV entry covers them [S8] [S9], search DNS and proxy logs for the listed indicators back to April 2026, check any Plerdy use, and revoke sessions for any user with a likely hit.

Key judgments

VERY LIKELY · HIGH CONFIDENCE

Over the next 6 to 12 months, state and criminal actors will very likely keep using packaged iOS and Android n-day kits through compromised websites and ad infrastructure, because DarkSword was posted publicly and Coruna-family code is already widespread. [S2] [S3] [S19] [S22]

LIKELY · MODERATE CONFIDENCE

The operators will likely move to new delivery and exfiltration infrastructure within weeks of Sekoia's publication, so the published domains and IPs are more useful for retrospective hunting than for future blocking. One lookalike is already offline and Sekoia is working with CERTs on disruption. [S2] [S6]

LIKELY · MODERATE CONFIDENCE

More compromised sites or lookalike domains from this campaign, including some with a U.S. connection, will likely be identified in the coming weeks, since Sekoia holds further indicators for national CERTs and is working with them on victim identification. [S2] [S6]

LIKELY · LOW CONFIDENCE

Cookies stolen in this campaign were likely used to reach webmail or other accounts without passwords. This rests on the payload design and the actor's earlier interest in cookies and session tokens; no source confirms an account takeover in this campaign. [S2] [S6] [S20] [S25]

UNLIKELY · LOW CONFIDENCE

A typical Indiana small or mid-size business is unlikely to be a deliberate target of this operation, though staff could be caught incidentally if they visit an affected site on an outdated phone, particularly in chemical manufacturing, defense supply or government roles. [S2] [S3] [S5]

INDICATORS OF COMPROMISE

Reported campaign indicators come from Sekoia's 4 November 2026 report, re-read for this update; Sekoia withholds further hosts and YARA rules for national CERTs and law enforcement, so the list is partial. Many are historical (the Plerdy window closed on 3 September 2026 and one lookalike is offline), and entries labeled related or historical come from other clusters and are not tied to this campaign.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`theowo[.]club`	Reverse-proxy lookalike of Raffles London at The OWO; served script from static.flux-telemetry[.]com. Sekoia lists it as offline. Date is domain creation.	REPORTED	2026-06-18	[S2] [S7]
domain	`america250[.]holiday`	Reverse-proxy lookalike of the America250 site; linked to delivery domain adsprism-stat[.]com. Date is domain creation.	REPORTED	2026-05-19	[S2] [S3] [S7]
domain	`static[.]flux-telemetry[.]com`	Delivery host for the fingerprint script and fingerprint endpoint. Date is domain creation.	REPORTED	2026-04-02	[S2] [S7]
domain	`edge-ord[.]clouds-stacks[.]com`	Delivery host acting as load balancer and redirector; used in the Plerdy injection. Date is domain creation.	REPORTED	2026-08-26	[S2]
domain	`ad[.]starx-net[.]com`	Exfiltration host for all three chains; also serves Class B stages. Date is domain creation.	REPORTED	2026-04-03	[S2] [S3] [S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`adsprism-stat[.]com`	Malicious delivery domain tied to the America250 lookalike.	REPORTED		[S2] [S7]
domain	`ads-it-assets[.]com`	Redirect target of the clouds-stacks load balancer.	REPORTED		[S2]
domain	`cdn[.]adv-static[.]com`	Redirect target of the clouds-stacks load balancer.	REPORTED		[S2]
domain	`wpvortex-mod[.]com`	Redirect target of the clouds-stacks load balancer.	REPORTED		[S2]
domain	`assets-int[.]com`	Redirect target of the clouds-stacks load balancer.	REPORTED		[S2]
domain	`a[.]plerdy[.]com`	Legitimate analytics host, compromised from 27 August to 3 September 2026. Treat hits as suspicious only inside that window; not malicious infrastructure in itself.	REPORTED	2026-08-27	[S2] [S3] [S7]
domain	`flux-telemetry[.]com`	Parent domain of the reported delivery host, and a hunting keyword in secondary coverage. Hunt on the parent to catch sibling hosts.	DERIVED		[S2] [S7]
domain	`clouds-stacks[.]com`	Parent domain of the reported redirector host, and a hunting keyword in secondary coverage. Hunt on the parent to catch sibling hosts.	DERIVED		[S2] [S7]
domain	`starx-net[.]com`	Parent domain of the reported exfiltration host, and a hunting keyword in secondary coverage. Hunt on the parent to catch sibling hosts.	DERIVED		[S2] [S7]
ipv4	`109[.]104[.]106[.]107`	Resolved from static.flux-telemetry[.]com; AS395092 Shock Hosting LLC. Hosting IPs may be shared or reassigned.	REPORTED		[S2]
ipv4	`95[.]133[.]231[.]28`	Resolved from edge-ord.clouds-stacks[.]com; AS219399 servinga GmbH.	REPORTED		[S2]
ipv4	`195[.]58[.]140[.]105`	Resolved from ad.starx-net[.]com; AS395092 Shock Hosting LLC.	REPORTED		[S2]
ipv4	`192[.]121[.]46[.]25`	Resolved from america250[.]holiday; AS9009, listed by Sekoia as EDIS GmbH.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`188[.]190[.]17[.]232`	Resolved from theowo[.]club; AS57169 EDIS GmbH.	REPORTED		[S2]
url	`hxxps[://]static[.]flux-telemetry[.]com/module/5b4c8fea5cbcee273e8d830f52-temfp[.]js`	UltimateFingerprinter script loaded by the injected code on the gas company's site. Sekoia says the file name is identical across victims.	REPORTED		[S2]
url	`hxxps[://]edge-ord[.]clouds-stacks[.]com/module/5b4c8fea5cbcee273e8d830f52-temfp[.]js`	UltimateFingerprinter script loaded through the compromised Plerdy tracker.	REPORTED		[S2]
url	`hxxps[://]a[.]plerdy[.]com/public/js/click/main[.]js`	Plerdy tracker file modified during the compromise window. The file is legitimate outside that window.	REPORTED	2026-08-27	[S2] [S3]
url	`hxxps[://]static[.]flux-telemetry[.]com/api/uGmlx2pmMHU1jq7wZU2QWgeC28vbXalf/v1`	Fingerprint submission endpoint (POST, JSON). Expect the path token to vary.	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com/api/<NONCE>/v1`	Class B stage 1: code execution (CVE-2025-43529) with PAC bypass (CVE-2026-20700).	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com/api/<NONCE>/v2`	Class B stage 2: sandbox escape (CVE-2025-14174, then CVE-2025-43510).	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com/api/<NONCE>/v3`	Class B stage 3: kernel read/write (CVE-2025-43520) and the post-exploitation harvester.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
url	`hxxps[://]ad[.]starx-net[.]com:8881/telemetry/v12`	Exfiltration endpoint used by all three chains.	REPORTED		[S2] [S3] [S7]
port	`8881`	Exfiltration port on the starx-net host. Outbound HTTPS on this port from a phone is unusual, but check for false positives.	REPORTED		[S2] [S3]
http-request	`POST /api/<nonce>/v1 with Content-Type: application/json and a fingerprint body`	Fingerprint exchange. The delivery host returns an empty 200 OK when screen dimensions are implausible or navigator.maxTouchPoints is 0.	REPORTED		[S2]
http-request	`POST /telemetry/v12 with JSON fields category, description, path, deviceUUID, size, data`	Class A exfiltration to port 8881. Sekoia shows category, description and path set to only_cookies and size set to 2097152.	REPORTED		[S2]
http-request	`HTTP request headers Filename and X-Device-Id`	Sent by AndroSnitch, which uses libcurl for exfiltration. X-Device-Id is hardcoded, but Sekoia does not publish its value.	REPORTED		[S2]
http-request	`GET /module/*-temfp.js`	Generalized from the two reported fingerprint script URLs to catch the same path on new hosts. May produce false positives and is visible only with TLS inspection or full URL logging.	DERIVED		[S2]
filename	`5b4c8fea5cbcee273e8d830f52-temfp.js`	UltimateFingerprinter script, appended to a minified AngularJS library that makes up about 98% of the file (about 2.3 MB).	REPORTED		[S2]
filename	`libexploit.so`	Internal name of the shared library inside the AndroSnitch shellcode.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/private/var/mobile/Containers/Data/Application/<UUID>/Library/Cookies/Cookies.binarycookies`	Legitimate iOS cookie store targeted for theft. Not malicious on its own.	REPORTED		[S2]
filepath	`/var/mobile/Cookies/`	Legitimate iOS cookie location targeted for theft. Not malicious on its own.	REPORTED		[S2]
filepath	`/data/data/com.android.chrome/app_chrome/Default/Cookies`	Chrome cookie database read by AndroSnitch. Legitimate file.	REPORTED		[S2]
filepath	`/data/data/com.android.chrome/app_chrome/Default/Login Data`	Chrome saved-login database read by AndroSnitch. Legitimate file.	REPORTED		[S2]
filepath	`/data/data/com.android.chrome/app_chrome/Default/History`	Chrome history database read by AndroSnitch. Legitimate file.	REPORTED		[S2]
filepath	`/data/misc/apexdata/com.android.wifi/WifiConfigStore.xml`	Android saved Wi-Fi configuration targeted by AndroSnitch. Legitimate file.	REPORTED		[S2]
filepath	`/data/misc/apns/0/WifiConfigStore.xml`	Second Wi-Fi configuration path targeted by AndroSnitch.	REPORTED		[S2]
filename	`sms.db`	Legitimate iOS message store targeted by Class B.	REPORTED		[S2]
filename	`Envelope Index`	Legitimate Apple Mail index targeted by Class B.	REPORTED		[S2] [S3]
filename	`Protected Index`	Legitimate Apple Mail index targeted by Class B.	REPORTED		[S2] [S3]
filename	`Accounts3.sqlite`	Legitimate iOS accounts database targeted by Class B.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`History.db`	Legitimate Safari history database targeted by Class B.	REPORTED		[S2]
filename	`wifi_passwords.txt`	Named by Sekoia in Class B collection.	REPORTED		[S2]
other	`VDGH_TOKEN_REF`	Marker cookie set by Class A and checked by Classes A and B as a replay guard. A date error makes it last about one minute instead of a day. Class C does not use it.	REPORTED		[S2]
other	`only_cookies`	JSON value in Class A exfiltration data.	REPORTED		[S2]
other	`SM-S938B`	Samsung Galaxy S25 Ultra model identifier. The Android chain stops if it detects this device.	REPORTED		[S2] [S3]
other	`UltimateFingerprinter`	Name of the fingerprint script; 394 fields from 61 collectors. Useful as a string search.	REPORTED		[S2] [S7]
other	`ASDhdhashdasads`	Class A JavaScript function name (process ID sweep). Useful as a string search on captured scripts.	REPORTED		[S2]
other	`AHSDhdashashs`	Class A JavaScript function name (collector). Useful as a string search on captured scripts.	REPORTED		[S2]
sha256	`a7d2493df00565c21587b0cad2a9fe7ca1e5590acf796da6e499be0ffde44cc3`	Class-A-Stage1 (Sekoia final hash list).	REPORTED		[S2]
sha256	`bee3e014e3df87ddce0250b0985b87f6868a427a7b650a74b7ffedb9d57f3088`	Class-A-Stage2 (final hash list) and the Class A section table.	REPORTED		[S2]
sha256	`c170fda024183645c0aa681149304e50506509c3498bb6b9a5f5ced6aa73e5fa`	Class-B-Stage1 (final hash list).	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`35c0cd19a7334b544c193e392bcd9a8f1d1f43cf6b61be5bf1d9e35537aff2ef`	Class B /v1 (Class B section table; differs from the final-list hash for this stage).	REPORTED		[S2]
sha256	`2ffb35e3f9e55286a930fb887e73764a913166648135fe0ca7551736d97d7bfa`	Class-B-Stage2 (final hash list).	REPORTED		[S2]
sha256	`621112712ec515e8791129c62feda8fff6654a0116882401609503cacc08054a`	Class B /v2 (Class B section table; differs from the final-list hash for this stage).	REPORTED		[S2]
sha256	`69b6cb327a4d5da99399718f6a66f84de69f89425b0a31f2dcee0682f811596f`	Class-B-Stage3 and /v3 (final hash list and Class B section table).	REPORTED		[S2]
sha256	`ae3241d96cc2d99538c7aff60f382cc8dac13859bcbea3ee84992d24d22a8108`	Class C JavaScript for Chrome 139-144 (Class C section table).	REPORTED		[S2]
sha256	`41e6fd33a30d36dabff9ea408d9766a6583edcc107968f6dc1499f2586381967`	Class C JavaScript for Chrome 145 (Class C section table).	REPORTED		[S2]
sha256	`29d283ebd08d0cd3b2e6f4a67718d3d6e7a6be01d0613d716bce218dba57a928`	Class-C-Stage1-JS (final hash list).	REPORTED		[S2]
sha256	`06c17b31d36838f3d29044784aa047d5c2d9174d3356c1211cf25f9df677445f`	Class-C-Stage2-JS (final hash list).	REPORTED		[S2]
sha256	`183d62d682aea8018491c8559544e8d6a9ab0e1abd05ecbb6c97daa4f438d2b8`	Class-C-Stage2-CVE-2025-27038 (final hash list); labeled shellcode in the Class C section table.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`387a7fb768db1350a9788d9704e7a72abe07152734e0ff026af72b417e36268c`	AndroSnitch (final hash list and Class C section table).	REPORTED		[S2]
sha256	`493f8d0a9f0f89c51f74d5f1b5592871bf974b16035e43d202ea91ff12e5dfd4`	DarkSword kit sample Sekoia references through VirusTotal, uploaded September 2026. Not in its hash list and not specific to this campaign.	REPORTED		[S2]
domain	`static[.]cdncounter[.]net`	Related, not this campaign: UNC6353 DarkSword delivery through Ukrainian watering holes. Google does not tie UNC6353 to APT29 in the sources reviewed.	REPORTED		[S19]
domain	`sqwas[.]shapelie[.]com`	Related, not this campaign: UNC6353 GHOSTBLADE exfiltration server.	REPORTED		[S19]
sha256	`2e5a56beb63f21d9347310412ae6efb29fd3db2d3a3fc0798865a29a3c578d35`	Related, not this campaign: extracted GHOSTBLADE sample (UNC6353).	REPORTED		[S19]
filepath	`/private/var/tmp/wifi_passwords.txt`	Sekoia names only the file wifi_passwords.txt. This full path comes from Google's YARA rule for GHOSTBLADE, a related DarkSword payload, so its use in this campaign is inferred and unconfirmed.	DERIVED		[S2] [S19]
filepath	`/private/var/tmp/wifi_passwords_securityd.txt`	Related, not this campaign: path in Google's GHOSTBLADE YARA rule.	REPORTED		[S19]
filepath	`/private/var/containers/Shared/SystemGroup/systemgroup.com.apple.osanalytics/DiagnosticReports/`	Related, not this campaign: legitimate iOS crash report folder that GHOSTBLADE clears.	REPORTED		[S19]
domain	`snapshare[.]chat`	Related, not this campaign: UNC6748 DarkSword delivery decoy from November 2025.	REPORTED		[S19]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`62[.]72[.]21[.]10`	Related, not this campaign: UNC6748 GHOSTKNIFE C2 from November 2025.	REPORTED		[S19]
ipv4	`72[.]60[.]98[.]48`	Related, not this campaign: UNC6748 GHOSTKNIFE C2 from November 2025.	REPORTED		[S19]
domain	`sahibndn[.]io`	Related, not this campaign: PARS Defense DarkSword delivery in Turkey.	REPORTED		[S19]
domain	`e5[.]malaymoil[.]com`	Related, not this campaign: PARS Defense DarkSword delivery in Malaysia.	REPORTED		[S19]
domain	`ad-track[.]live`	Related, not this campaign: reached through a World Cup-themed ad in iVerify's P7 DarkSword reporting, as summarized by The Hacker News.	REPORTED		[S3]
domain	`track-adv[.]com`	Historical: APT29-linked delivery against Mongolian government sites in November 2023 and July 2024.	REPORTED		[S20]
domain	`ceo-adviser[.]com`	Historical: APT29-linked delivery against a Mongolian government site in February 2024.	REPORTED		[S20]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker plants a script loader on a site the target is likely to visit: by changing a page or an existing JavaScript library, by proxying a real site through a lookalike domain and adding the script, or by altering a third-party analytics tracker. After the page loads, a window.onload handler pulls UltimateFingerprinter, placed behind a large block of AngularJS dead code, which posts 394 browser and device fields to the delivery host. If the screen size and touch-point checks look plausible for a phone, the server returns a chain matched to the device: Class A for iOS 16.7, Class B (DarkSword) for iOS 18.5, or Class C (AndroSnitch) for Chrome 139-145 on Android. In Class A, CVE-2025-43529 gives WebKit code execution and CVE-2024-27834 bypasses PAC; the other classes add sandbox escape and kernel or driver flaws. The chains then read cookies and other stored data, send them to ad[.]starx-net[.]com on port 8881, and leave no persistence [S2] [S3] [S5].

Threat actor

APT29 · also tracked as Midnight Blizzard, Cozy Bear, The Dukes, Nobelium, Yttrium

Attribution confidence: Moderate · **Motivation:** Espionage. Targeting centers on Ukraine, with victims also in the U.S. and Europe. · **Suspected origin:** Russia (linked to the SVR foreign intelligence service)

This is Sekoia's assessment, stated as moderate to high confidence. It rests on overlap with the 2024 Mongolian government watering holes that Google tied to APT29 with moderate confidence, a partner CERT's finding of traces on one compromised site that match a 2025 APT29 watering hole, infrastructure patterns, and victimology [S2] [S20]. This report rates it Moderate because it comes from one vendor and some of the evidence is not public. CISA's KEV entry does not name an actor [S6] [S8], and no government has confirmed the attribution in the sources reviewed. Sekoia describes the AndroSnitch and AndroSnatch resemblance as a hint of lineage and not as conclusive [S2]. Google separately tracks UNC6353, a suspected Russian espionage cluster using DarkSword on Ukrainian sites; the sources reviewed do not say it is APT29 [S19].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1583.001 Acquire Infrastructure: Domains	Registered lookalike and delivery domains between April and August 2026. [S2]	Monitor newly registered domains that imitate brands or events your staff use.
Resource Development	T1584.004 Compromise Infrastructure: Server	Compromised legitimate web servers to inject the loader. The entry method is not reported. [S2]	File integrity monitoring on web roots and templates; review CMS admin logins.
Resource Development	T1608.004 Stage Capabilities: Drive-by Target	Prepared compromised and proxied sites to serve the fingerprint script. [S2]	Scan your own sites for unexpected script elements added on window.onload.
Resource Development	T1588.005 Obtain Capabilities: Exploits	Reused packaged exploits including DarkSword; Sekoia frames this as reuse of commercial surveillance vendor tooling. [S2] [S3] [S19]	Track DarkSword and Coruna indicators from vendors.
Reconnaissance	T1592.004 Gather Victim Host Information: Client Configurations	UltimateFingerprinter gathers 394 fields, then the server filters on platform, version and basic plausibility. [S2]	Proxy logs showing POSTs to /api/<token>/v1 on rare domains just after a page load.

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1189 Drive-by Compromise	Visiting a compromised or lookalike site in a vulnerable mobile browser triggers the chain, with no further action required. [S1] [S2]	DNS and proxy hits on listed delivery domains from mobile device ranges.
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	Plerdy's main.js tracker was altered for one week, reaching mostly Ukrainian customer sites. [S2] [S3] [S6]	Inventory third-party scripts; use Subresource Integrity and CSP reporting where practical.
Initial Access	T1566.002 Phishing: Spearphishing Link	Suspected only: Sekoia assesses the lookalikes may have supported spear-phishing around diplomatic or high-profile events. No lure has been published. [S2] [S5] [S7]	Search mail logs for links to the listed lookalike domains.
Execution	T1203 Exploitation for Client Execution	WebKit and V8 flaws (CVE-2025-43529, CVE-2026-3910) give code execution in the browser; CVE-2024-27834 or CVE-2026-20700 then defeats PAC on iOS. [S2] [S27] [S32]	Limited on phones; rely on MDM patch posture and mobile threat defense alerts.
Execution	T1059.007 Command and Scripting Interpreter: JavaScript	Fingerprinting, exploit delivery and Class A and B post-exploitation logic are JavaScript. [S2] [S19]	Inspect served JavaScript where TLS inspection exists; hunt for script names in logs.
Privilege Escalation	T1404 Exploitation for Privilege Escalation	CVE-2025-43510 and CVE-2025-43520 on iOS and CVE-2025-27038 on Adreno Android devices extend access past the browser sandbox. [S2] [S19] [S33]	Mobile threat defense alerts; review device patch levels.
Defense Evasion	T1497 Virtualization/Sandbox Evasion	Server returns nothing for implausible screen sizes or zero touch points; the Android chain stops on model SM-S938B. Sekoia does not state the purpose of these checks. [S2] [S3]	When testing, expect an empty 200 OK from non-phone browsers, so a clean sandbox result does not prove a site is clean.
Defense Evasion	T1027 Obfuscated Files or Information	Script placed behind about 2.3 MB of dead AngularJS code, which Sekoia suggests may overwhelm automated LLM analysis or make the file look legitimate. [S2]	Flag unusually large scripts from rare domains.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1539 Steal Web Session Cookie	All chains take browser cookies; Class A takes Cookies.binarycookies and Class C reads Chrome's Cookies database. [S1] [S2] [S6]	Sign-in anomalies showing one session across different IPs or networks.
Credential Access	T1634.001 Credentials from Password Store: Keychain	Class B takes Keychain entries. [S1] [S2] [S6]	No practical network-side signal; treat a likely Class B hit as full credential exposure.
Credential Access	T1555.003 Credentials from Password Stores: Credentials from Web Browsers	AndroSnitch reads Chrome's Login Data. [S1] [S2] [S6]	Watch for logins from new locations using passwords saved on the phone.
Collection	T1409 Stored Application Data	Class B collects WhatsApp and Telegram databases, Mail indexes, Notes, Health and Safari history. [S1] [S2] [S3]	Not visible from the network; depends on triage of the device.
Collection	T1636.004 Protected User Data: SMS Messages	Class B reads sms.db for SMS and iMessage content. [S2] [S6]	Not visible from the network; depends on triage of the device.
Collection	T1430 Location Tracking	Class B harvests cached location data from Routined and locationd caches. [S1] [S2]	Not visible from the network; depends on triage of the device.
Collection	T1533 Data from Local System	Chains collect photos, iCloud Drive files, wifi_passwords.txt and WifiConfigStore.xml. [S2] [S3]	Large uploads from mobile devices to rare hosts on port 8881.
Exfiltration	T1041 Exfiltration Over C2 Channel	Data goes to ad[.]starx-net[.]com:8881/telemetry/v12; AndroSnitch uses libcurl. [S2] [S3]	TLS SNI or DNS hits on the host; outbound volume on port 8881.
Command and Control	T1571 Non-Standard Port	HTTPS exfiltration uses port 8881. [S2] [S3]	Alert on egress from mobile or guest VLANs to uncommon ports.
Lateral Movement	T1550.004 Use Alternate Authentication Material: Web Session Cookie	Assessed follow-on use, not observed in this campaign: stolen cookies could let the attacker reuse logged-in sessions such as webmail without a password. [S6]	Compare session IDs against user agent, ASN and country in identity logs.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

DNS and proxy hits on campaign infrastructure `SPLUNK SPL`

```
(index=dns OR index=proxy) earliest=-220d (query IN ("*flux-telemetry.com","*clouds-stacks.com","*starx-net.com","*adsprism-stat.com","*ads-it-assets.com","*adv-static.com","*wpvortex-mod.com","*assets-int.com","*america250.holiday","*theowo.club") OR url IN ("*flux-telemetry.com*","*clouds-stacks.com*","*starx-net.com*","*adsprism-stat.com*","*ads-it-assets.com*","*adv-static.com*","*wpvortex-mod.com*","*assets-int.com*","*america250.holiday*","*theowo.club*") OR dest_ip IN ("109.104.106.107","95.133.231.28","195.58.140.105","192.121.46.25","188.190.17.232")) | stats earliest(_time) AS first latest(_time) AS last count BY src_ip user query url dest_ip
```

Field names vary by source. Reaches back to April 2026, when the first delivery domains were created. Hosting IPs may be shared. Phones off the corporate network will not appear.

Fingerprint script and Plerdy tracker requests `SIGMA`

```
title: APT29 Mobile Watering Hole Script Retrieval
status: experimental
logsource:
  category: proxy
detection:
  selection_script:
    c-uri|contains: '-temfp.js'
  selection_tracker:
    cs-host: 'a.plerdy.com'
    c-uri|contains: '/public/js/click/main.js'
  condition: selection_script or selection_tracker
level: medium
```

Needs URL visibility through TLS inspection or an explicit proxy. Plerdy matches matter only from 2026-08-27 to 2026-09-03; filter by date during review.

TLS connection to exfiltration host `SURICATA`

```
alert tls $HOME_NET any -> $EXTERNAL_NET any (msg:"Possible APT29 mobile campaign exfiltration host in SNI"; tls.sni; content:"starx-net.com"; nocase; endswith; classtype:trojan-activity; sid:9200101; rev:1;)
```

Local sid. Add a companion rule for port 8881 if your sensors see guest or mobile traffic.

Session reuse across networks `KQL`

```
SigninLogs
| where TimeGenerated > ago(30d)
| where ResultType == 0 and isnotempty(SessionId)
| summarize IPs=make_set(IPAddress, 20), ASNs=make_set(AutonomousSystemNumber, 20),
Countries=make_set(Location, 20), UserAgents=make_set(UserAgent, 20), First=min(TimeGenerated),
Last=max(TimeGenerated) by UserPrincipalName, SessionId
| where array_length(ASNs) > 1 and array_length(Countries) > 1
```

Generic check for possible cookie replay, focused first on high-risk users and anyone with an infrastructure hit. Travel and VPNs will cause false positives. Extend retention if available, since the campaign began months ago.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS and iPadOS (Class A chain, delivered to iOS 16.7 and 16.7.10)	CVE-2024-27834: before 16.7.8 and 17.0 to before 17.5. Delivery filter covers 16.7 and 16.7.10; Sekoia says the exploits reportedly work from 16.0 to 17.4.	CVE-2024-27834: iOS and iPadOS 16.7.8, 17.5. CVE-2025-43529: iOS 18.7.3, 26.2; Apple's 16.7.16 notes do not list it.	CVE-2024-27834, CVE-2025-43529	5.5, 8.8	0.00598 (48.75th pct); 0.2565 (97.97th pct), scored 2026-11-04	CVE-2024-27834: Yes (added 2026-11-04); CVE-2025-43529: Yes (added 2025-12-15)	2026-11-18; 2026-01-05
Apple macOS, Safari, tvOS and watchOS (KEV scope for CVE-2024-27834; no sources report these platforms being targeted in this campaign)	macOS before 14.5, Safari before 17.5, tvOS before 17.5, watchOS before 10.5	macOS Sonoma 14.5, Safari 17.5, tvOS 17.5, watchOS 10.5. Current macOS releases: 27.2, 26.7.2, 15.8.2, 14.8.9.	CVE-2024-27834	5.5	0.00598 (48.75th pct)	Yes (added 2026-11-04)	2026-11-18

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS (Class B chain, DarkSword, iOS 18.5)	Campaign used iOS 18.5; DarkSword broadly supports iOS 18.4-18.7	iOS 18.7.2/26.1 (CVE-2025-43510, CVE-2025-43520); iOS 18.7.3/26.2 (CVE-2025-43529, CVE-2025-14174); iOS 26.3 (CVE-2026-20700). Current releases: iOS 27.2, 26.7.2, 18.7.11.	CVE-2025-43529, CVE-2026-20700, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520	8.8, 7.8, 8.8, 7.8, 5.5	0.2565; 0.01679; 0.55334; 0.00355; 0.00425 (scored 2026-11-04)	Yes (added 2025-12-15, 2026-02-12, 2025-12-12, 2026-03-20, 2026-03-20 in CVE order)	2026-01-05, 2026-03-05, 2026-01-02, 2026-04-03, 2026-04-03 in CVE order
Google Chrome for Android (Class C chain)	Delivery covers Chrome 139-145 excluding 143	Chrome 146.0.7680.75 for CVE-2026-3910	CVE-2026-3910	8.8	0.02693 (85.94th pct)	Yes (added 2026-03-13)	2026-03-27
Qualcomm Adreno GPU driver on Android (Class C chain)	Qualcomm chipsets listed in the CVE record and June 2025 Qualcomm bulletin	Fix to OEMs in May 2025; Android patch level 2025-08-05	CVE-2025-27038	7.5	0.01044 (64.22nd pct)	Yes (added 2025-06-03)	2025-06-24

Immediate (0–24 hours)

- Pull an MDM report of iOS, iPadOS, macOS, Android and Chrome versions. Force updates for anything below current Apple releases, Chrome below 146, or Android below the 2025-08-05 patch level, starting with executives, administrators and traveling staff. `IT OPS` [S8] [S13] [S23] [S34]
- Search DNS, proxy, firewall and mobile security logs back to April 2026 for the listed domains and IPs, and for Plerdy tracker requests from 27 August to 3 September 2026. `SOC` [S2]
- Block the listed malicious delivery, exfiltration and lookalike domains at DNS and proxy layers. Do not block a.plerdy[.]com solely for this campaign without checking business use. `SOC` [S2]

- For any device with an infrastructure hit, keep logs first, then update and reboot it, revoke all sessions and tokens, and rotate passwords saved on it plus any Wi-Fi passwords it stored. `SOC` [S1] [S2] [S6]
- Federal agencies and contractors running federal systems should check CISA's BOD 26-04 and forensic triage terms in the KEV entry before the 18 November due date. Other organizations can use the same two-week date as a useful outer limit. `LEADERSHIP` [S8] [S10] [S36]
- If your organization is a chemical sector member or supplier, confirm whether staff use trade association sites, and follow any guidance from the association. `LEADERSHIP` [S1] [S2]

Short term (1–7 days)

- Identify devices limited to iOS 16 (iPhone 8, 8 Plus, X) and iOS 15. Confirm each is on the last release, then replace it or remove it from corporate access, since Apple's 16.7.16 notes do not list CVE-2025-43529. `IT OPS` [S13] [S18] [S21]
- Set conditional access rules that block mail and SaaS access from mobile devices below a minimum OS and patch level, including BYOD. `IT OPS` [S2]
- Review your public websites for unexpected script tags and changes to shared JavaScript libraries, and remove the Plerdy tracker or confirm its current file is clean. `IT OPS` [S2]
- Brief high-risk staff on the campaign and turn on Lockdown Mode for those who accept its limits or cannot update immediately. `SOC` [S19] [S20]
- Run the session-reuse hunt for high-risk users and review webmail and SaaS access logs for unfamiliar sessions. `SOC` [S6]

Long term

- Add phones and tablets to vulnerability management with a written patch deadline, and treat KEV-listed mobile flaws like server flaws. CVE-2024-27834 shows an old, medium-severity flaw can reach KEV more than two years after its patch. `LEADERSHIP` [S8] [S10]
- Reduce the value of stolen cookies with short session lifetimes, device-bound or compliant-device access rules, and continuous access evaluation where supported. `IT OPS` [S6]
- Deploy a mobile threat defense product or managed DNS on mobile devices so that traffic off the corporate network is visible. `LEADERSHIP` [S2]
- Keep an inventory of third-party scripts on your websites and use Content Security Policy and Subresource Integrity to limit the effects of a tracker compromise. `IT OPS` [S2] [S3]
- Set a hardware lifecycle policy that retires phones before vendors stop full security updates, and restrict sensitive access from older hardware. `LEADERSHIP` [S13] [S18]

Workarounds & compensating controls

- Use Lockdown Mode on iPhones that cannot be updated right away. Google recommends it when updating is not possible and reported it blocked the 2023 iOS chain; BleepingComputer reports it also stops Coruna and DarkSword. `IT OPS` [S19] [S20] [S21]
- Keep Chrome automatic updates on through managed Google Play, and restrict corporate data to compliant browsers on Android. `IT OPS` [S32] [S34]

- Do not store corporate passwords in phone browsers and do not keep admin portal sessions on phones. Phishing-resistant MFA helps with password theft but does not stop replay of a stolen session. `LEADERSHIP` [S1] [S2] [S6]
- Rebooting ends a running payload because none persists, but does not undo data theft, so use it as a stopgap and not as remediation. `IT OPS` [S1] [S6]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] BleepingComputer: Hackers use n-day exploits in zero-click attacks on iOS, Android devices
Published 2026-11-04 · `B2` Usually reliable, probably true
Briefing source; summarizes Sekoia.

[S2] Sekoia TDR: Poisoned source: APT29 watering holes targets mobile devices with n-day exploits
Published 2026-11-04 · `A2` Completely reliable, probably true
Primary research. Attribution comes from one vendor and partly from non-public data.

[S3] The Hacker News: APT29-Linked Hackers Hijack Web Analytics Script to Deliver iOS and Android Exploits
Published 2026-11-04 · `B2` Usually reliable, probably true
Briefing source. Adds context on P7 DarkSword, DeadTag and Zimperium's Coruna figures.

[S4] The Hacker News: Hackers Exploit Patched Apple Flaw to Deliver Info-Stealing Malware, CISA Says
Published 2026-11-05 · `B3` Usually reliable, possibly true
Briefing source on the KEV addition. Names CVE-2025-43529 for both the WebKit and PAC roles, an apparent error.

[S5] SecurityWeek: Russia-linked hackers hit iOS, Android devices with exploit chains via watering holes
Published 2026-11-05 · `B2` Usually reliable, probably true
Briefing source; title from URL. Describes the first iOS chain as reusing DarkSword's initial code execution.

[S6] Help Net Security: Article on the APT29 watering-hole campaign against mobile devices
Published 2026-11-04 · `B2` Usually reliable, probably true
Secondary; adds CERT-UA coordination, the Australian clinic and an update on the KEV listing.

[S7] GBHackers: Russian Hackers Create Fake US and UK Websites to Target Visitors With Mobile Exploits
Published 2026-11-04 · `C2` Fairly reliable, probably true
Secondary. Its indicator table agrees with Sekoia.

[S8] CISA: Known Exploited Vulnerabilities catalog JSON feed, version 2026.11.04
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary. Read for the CVE-2024-27834 entry; the other seven were checked through NVD KEV fields.

[S9] CVE Program: CVE-2024-27834 record
Published 2024-05-13 · **A1** Completely reliable, confirmed by other sources
CISA ADP container, updated 2026-11-05, holds KEV data and the Sekoia reference.

[S10] NVD: CVE-2024-27834
Published 2024-05-14 · **A1** Completely reliable, confirmed by other sources
KEV fields, CVSS and fix bounds. Last modified 2026-11-05.

[S11] Apple: About the security content of iOS 16.7.8 and iPadOS 16.7.8
Published 2024-05-13 · **A1** Completely reliable, confirmed by other sources
Lists CVE-2024-27834 under WebKit; entry added 2024-06-10.

[S12] Apple: About the security content of Safari 17.5
Published 2024-05-13 · **A1** Completely reliable, confirmed by other sources
Credits Manfred Paul with Trend Micro ZDI.

[S13] Apple: Apple security releases
Published · **A1** Completely reliable, confirmed by other sources
Living page read 2026-11-05. Newest listed releases are from 26 and 29 October 2026.

[S14] Apple: About the security content of iOS 18.7.3 and iPadOS 18.7.3
Published 2025-12-12 · **A1** Completely reliable, confirmed by other sources
Lists CVE-2025-43529 and CVE-2025-14174.

[S15] Apple: About the security content of iOS 26.3 and iPadOS 26.3
Published 2026-02-11 · **A1** Completely reliable, confirmed by other sources
Lists CVE-2026-20700 under dyld.

[S16] Apple: About the security content of iOS 18.7.5 and iPadOS 18.7.5
Published 2026-02-11 · **A1** Completely reliable, confirmed by other sources
Does not list CVE-2026-20700.

[S17] Apple: About the security content of iOS 18.7.7 and iPadOS 18.7.7
Published 2026-03-24 · **A1** Completely reliable, confirmed by other sources
DarkSword note; offered to more devices from 2026-04-01. Does not list CVE-2026-20700.

[S18] Apple: About the security content of iOS 16.7.16 and iPadOS 16.7.16
Published 2026-05-11 · **A1** Completely reliable, confirmed by other sources
Lists only CVE-2026-28950.

[S19] Google Threat Intelligence Group: The Proliferation of DarkSword: iOS Exploit Chain Adopted by Multiple Threat Actors
Published 2026-03-18 · **A1** Completely reliable, confirmed by other sources
Primary on DarkSword, per-CVE fixes and Lockdown Mode guidance.

[S20] Google Threat Analysis Group: State-backed attackers and commercial surveillance vendors repeatedly use the same exploits
Published 2024-08-29 · **A2** Completely reliable, probably true
Earlier APT29-linked mobile watering holes, assessed with moderate confidence.

[S21] BleepingComputer: New DarkSword iOS exploit used in infostealer attack on iPhones
Published 2026-03-18 · **B2** Usually reliable, probably true
Updated 2026-03-20 with Apple's comments on protected releases.

[S22] BleepingComputer: Apple expands iOS 18 updates to more iPhones to block DarkSword attacks
Published 2026-04-01 · **B1** Usually reliable, confirmed by other sources
Reports public posting of the kit on GitHub in March 2026.

[S23] Android: Android Security Bulletin, August 2025
Published 2025-08-01 · **A1** Completely reliable, confirmed by other sources
CVE-2025-27038 at patch level 2025-08-05.

[S24] BleepingComputer: Qualcomm fixes three Adreno GPU zero-days exploited in attacks
Published 2025-06-02 · **B1** Usually reliable, confirmed by other sources
Used for OEM fix timing.

[S25] BleepingComputer: Hotel Wi-Fi attacks use custom malware to breach Microsoft 365 accounts
Published 2026-08-03 · **B2** Usually reliable, probably true
Related Midnight Blizzard sub-cluster activity reported by Microsoft.

[S26] FIRST: EPSS API results for the eight CVEs
Published 2026-11-04 · **A2** Completely reliable, probably true
Probability model output, not proof of exploitation. Scores dated 2026-11-04.

[S27] NVD: CVE-2025-43529
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S28] NVD: CVE-2026-20700
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S29] NVD: CVE-2025-14174
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S30] NVD: CVE-2025-43510
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S31] NVD: CVE-2025-43520
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S32] NVD: CVE-2026-3910
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S33] NVD: CVE-2025-27038
Published · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S34] CVE Program: CVE-2026-3910 record
Published · **A1** Completely reliable, confirmed by other sources
Chrome fixed version 146.0.7680.75.

[S35] CVE Program: CVE-2025-14174 record
Published · **A1** Completely reliable, confirmed by other sources
Describes the ANGLE flaw in Chrome on Mac; the Apple link comes from Apple and Google sources.

[S36] CIQ: BOD 26-04: three days to patch, and a harder question underneath
Published 2026-07-23 · **C3** Fairly reliable, possibly true
Vendor summary, used because CISA's directive page returned HTTP 403. Verify against CISA.

[S37] Qualys: Meet CISA BOD 26-04 Requirements
Published 2026-10 · **B3** Usually reliable, possibly true
Vendor documentation on directive factors and triage. Verify against CISA.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2023-11-01	Start of the APT29-linked Mongolian government watering holes that Google later reported (month-level date).	[S20]
2024-03-01	CVE-2024-27834 shown at Pwn2Own Vancouver (month-level date).	[S4]
2024-05-13	Apple fixes CVE-2024-27834 in iOS 16.7.8, iOS 17.5, Safari 17.5 and other releases.	[S9] [S11] [S12]
2025-11-01	DarkSword in use by at least this month (month-level date).	[S19]
2025-12-12	Apple releases iOS 18.7.3, fixing CVE-2025-43529 and CVE-2025-14174.	[S14]
2026-02-11	Apple releases iOS 26.3, fixing CVE-2026-20700.	[S15]
2026-03-13	CVE-2026-3910 added to CISA KEV.	[S32]
2026-03-18	Google, Lookout and iVerify disclose DarkSword.	[S19] [S21]
2026-04-01	Apple offers iOS 18.7.7 to more devices as DarkSword protection.	[S17] [S22]
2026-04-02	static.flux-telemetry[.]com created; ad.starx-net[.]com follows on 3 April.	[S2]
2026-05-19	america250[.]holiday created.	[S2]
2026-06-18	theowo[.]club created.	[S2]
2026-08-26	edge-ord.clouds-stacks[.]com created one day before the Plerdy compromise.	[S2]
2026-08-27	Plerdy tracker compromise begins; ends 3 September 2026.	[S2] [S6]

Date	Event	Source
2026-10-15	Approximate date: Sekoia detects the campaign in mid-October 2026.	[S3] [S6]
2026-10-26	Apple ships iOS 27.2, 26.7.2 and 18.7.11, the current releases at the time of writing.	[S13]
2026-11-04	Sekoia publishes its report. CISA adds CVE-2024-27834 to KEV (catalog version 2026.11.04).	[S2] [S8]
2026-11-05	CISA data added to the CVE record cites the Sekoia report as a third-party advisory; KEV-focused press coverage appears.	[S4] [S5] [S9]
2026-11-18	Federal due date for CVE-2024-27834.	[S8] [S10]

Relevance to Indianapolis, Indiana & managed clients

No source names an Indiana victim. The clearest local link is the U.S. chemical industry trade association: Indiana manufacturers, chemical and materials firms, logistics providers and their suppliers may have staff who visit similar industry sites from phones. State and local government offices, universities and hospitals should check phones used by leaders, researchers and those who travel, particularly anyone with work tied to Ukraine, defense or international delegations, or who engaged with America250 events through an unfamiliar link. The KEV deadline binds federal civilian agencies only, but Indiana public bodies and contractors often use KEV as a planning baseline. Healthcare organizations should note an Australian clinic appeared among compromised sites, though it had no obvious strategic value, and Class B can take Health data and messages from a personal phone. For small and mid-size businesses, the realistic risk is an old phone or BYOD device holding a logged-in Microsoft 365 or webmail session. Managed IT clients should expect a mobile patch report covering iOS, iPadOS, macOS and Android, conditional access for minimum OS levels, and a check of any Plerdy use. Providers should treat phones used by technicians as high value, because a stolen cookie for an administrative portal could expose several clients.

Intelligence gaps

- The number of infected devices and the identity of victims are not public.
- Whether stolen cookies led to account access in any organization, U.S. or otherwise, is not reported.
- How the attacker compromised the legitimate sites and Plerdy is not reported, and no Plerdy statement was found.
- The name of the U.S. chemical trade association and how long it was compromised are not in the sources reviewed.
- Whether U.S. or Indiana devices were actually exploited, as opposed to merely exposed, is unknown.
- It is unclear whether the campaign is still active on compromised sites, or how long each site stayed compromised.
- The relationship between APT29 and Google's UNC6353, which also used DarkSword on Ukrainian sites, is not stated.
- CVE-2024-27834 was fixed in iOS 16.7.8, yet Sekoia reports the Class A delivery filter includes 16.7.10. Sekoia reads the version mismatch as a sign of reused code, but no source explains how the chain would

behave on 16.7.10.

- Apple's iOS 18.7.5 and 18.7.7 notes do not list CVE-2026-20700, and the CVE data shows only iOS 26.3 and peers as fixed. Apple says DarkSword is blocked in protected releases, but per-CVE backport detail for iOS 18 and iOS 16 is incomplete. Patching earlier links would still break the Class B chain as reported.
- Whether iPads were served these chains is not stated. Whether Macs are reachable is also unstated, though the zero touch-point filter suggests non-touch Macs would be refused; that is this report's inference.
- CISA's BOD 26-04 page and KEV alert returned HTTP 403, so the directive's terms here rest on vendor summaries and on the wording in the KEV entry. The forensic triage terms should be confirmed on cisa.gov.
- Why the delivery server skips Chrome 143 and why the Android chain stops on SM-S938B are unexplained.
- Watch for CERT-UA or other government advisories, a Plerdy statement, a Microsoft or Google view on the attribution, and the release of further indicators.

Other notes

- Changes since report CTI-20261104-03: CVE-2024-27834 is now in KEV (the earlier report showed no entry); the DarkSword and iOS 16 wording is corrected so that CVE-2024-27834 is shown as fixed in 16.7.8; and the earlier apparent disagreement over unused vulnerabilities is resolved in the note below.
- Press accounts differ on the chain. Sekoia, BleepingComputer and The Hacker News's campaign article map Class A to CVE-2025-43529 (code execution) and CVE-2024-27834 (PAC bypass) [S1] [S2] [S3]. The Hacker News's KEV article names CVE-2025-43529 for both roles, which appears to be an error [S4]. SecurityWeek describes the first chain as reimplementing DarkSword's initial code execution, without naming that CVE, and describes the second chain as DarkSword only [S5]. This report follows Sekoia.
- BleepingComputer reports four other vulnerabilities in unreachable code or alternate paths [S1]. Sekoia's text accounts for all four: CVE-2024-27808 and CVE-2024-27833 are dead code in Class A, and CVE-2025-31277 and CVE-2025-24201 are unused alternates in Class B [S2].
- 'Zero-click' needs care. The attack requires a page load in a vulnerable browser, and the lookalikes may have been sent by spear-phishing, so it differs from zero-click attacks over messaging apps. NVD scores CVE-2025-43529 and CVE-2026-3910 as requiring user interaction [S27] [S32].
- Sources differ on Plerdy's reach. Sekoia's own text says both hundreds and thousands of websites without reconciling them; BleepingComputer and Help Net Security say thousands, and SecurityWeek says hundreds [S1] [S2] [S5] [S6].
- Help Net Security says CISA did not attribute the exploitation or link it to Sekoia's findings [S6], while the CISA ADP data in the CVE record lists Sekoia's post as a third-party advisory [S9]. The KEV entry itself names no actor and sets out no campaign link [S8]. The timing and reference suggest a connection, but CISA has not stated one in the material reviewed.
- Sekoia's report has section tables and a final hash list with different hashes for some stages (Class B stages 1 and 2; Class C JavaScript). Both sets are listed with their labels, since Sekoia does not explain the difference. Verify against the report before relying on any single label [S2].
- CVE-2025-14174's record describes ANGLE in Chrome on Mac [S35]. Apple also lists it in iOS 18.7.3, and Google places it in the DarkSword chain as an ANGLE sandbox escape [S14] [S19].
- Related activity shows the wider trend. Microsoft tied CaptiveCrunch hotel Wi-Fi attacks to Storm-2945, a Midnight Blizzard sub-cluster that also targeted Microsoft 365 tokens and cookies [S25]. The Hacker News

reports the DeadTag criminal operation using expired analytics domains to push Coruna or P7 DarkSword, and Zimperium counted 608 domains delivering Coruna-family code as of October 2026 [S3].

- Sekoia cites open-source reporting that Ukraine's president stayed at Raffles London around 14 October 2026, in the context of the hotel lookalike. It is circumstantial and does not show he or his staff were targeted [S2].

CTI-20261105-03 v1.0 · Generated 2026-11-05 08:11 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.